

Tópicos Especiais em Inteligência Computacional Aplicada a Segurança de Sistemas

Aula 02

Programa de Pós-graduação em Computação Aplicada
Núcleo de Desenvolvimento Amazônico em Engenharia
Prof. Dr. Caio C. Moreira

Panorama da Segurança de Sistemas e Ameaças Cibernéticas

Principais Tipos de Ameaças

Malwares (software malicioso):

- Vírus, worms e trojans: propagação e efeitos destrutivos.
- Ransomware: criptografia de dados e exigência de resgate.
- Spyware e keyloggers: roubo de informações sigilosas.
- Rootkits e backdoors: ocultação e controle remoto.

Panorama da Segurança de Sistemas e Ameaças Cibernéticas

Principais Tipos de Ameaças

Ataques de Rede:

- DDoS (Distributed Denial of Service): sobrecarga de servidores e indisponibilidade de serviços.
- Intrusões e varreduras (port scanning, sniffing): exploração de vulnerabilidades.
- Man-in-the-Middle: interceptação e manipulação de comunicações.

Panorama da Segurança de Sistemas e Ameaças Cibernéticas

Principais Tipos de Ameaças

Engenharia social:

- Phishing e spear phishing.
- Uso de redes sociais e engenharia psicológica para manipulação de vítimas.
- Impacto humano como ponto frágil da segurança.

Panorama da Segurança de Sistemas e Ameaças Cibernéticas

Desafios na Detecção de Ataques

- Volume e diversidade: grande quantidade de eventos e logs a serem analisados em tempo real.
- Evasão: malwares polimórficos e metamórficos que alteram sua forma para escapar de assinaturas.
- Zero-day attacks: exploração de vulnerabilidades desconhecidas sem patch disponível.
- Ruído e falsos positivos: sobrecarga de analistas com alertas irrelevantes.
- Integração de dados heterogêneos: arquivos, tráfego de rede, eventos de sistema.

Panorama da Segurança de Sistemas e Ameaças Cibernéticas

Importância da Inteligência Computacional

- Automatização: ML e IA reduzem dependência de detecção manual.
- Generalização: identificação de padrões de ataques ainda não catalogados.
- Eficiência: sistemas inteligentes podem filtrar eventos e priorizar alertas críticos.
- Adaptação: aprendizado contínuo frente à evolução das ameaças.
- Interpretação: técnicas de explicabilidade (SHAP, LIME) permitem entender por que um ataque foi detectado.

Conceitos Básicos de Aprendizado de Máquina aplicados à Segurança

Diferença entre aprendizado supervisionado e não supervisionado

- Aprendizado supervisionado
 - Baseado em dados rotulados (ex.: benigno vs. malicioso).
 - O modelo aprende a mapear entradas para saídas conhecidas.
 - Exemplo em segurança: classificação de aplicativos Android em goodware ou malware.
 - Algoritmos comuns: SVM, Árvores de Decisão, Random Forest, XGBoost, Redes Neurais.

Conceitos Básicos de Aprendizado de Máquina aplicados à Segurança

Diferença entre aprendizado supervisionado e não supervisionado

- **Aprendizado não supervisionado**
 - Baseado em dados não rotulados, buscando padrões ou agrupamentos.
 - Útil quando não há rótulos claros ou para detectar comportamentos anômalos.
 - Exemplo em segurança: detecção de tráfego de rede anômalo sem conhecer previamente o ataque.
 - Algoritmos comuns: K-Means, DBSCAN, Isolation Forest, Autoencoders.

Ciclo de um sistema baseado em ML aplicado à segurança

- Coleta de dados
 - Logs, tráfego de rede, arquivos executáveis, eventos de execução.
 - Bases públicas de malwares (amostras brutas).
 - Bases Públicas com Características Extraídas (datasets prontos para ML)
- Pré-processamento
 - Limpeza e normalização dos dados.
 - Conversão de logs/arquivos em representações numéricas.
 - Tratamento de classes desbalanceadas (SMOTE, undersampling).
- Extração de características (feature engineering)
 - Permissões solicitadas por aplicativos.
 - Chamadas de API/sistema.
 - Frequência de pacotes em tráfego de rede.
 - Strings e entropia em executáveis.
- Treinamento do modelo
 - Escolha do algoritmo (supervisionado ou não supervisionado).
 - Ajuste de hiperparâmetros.
- Avaliação do modelo
 - Divisão em treino/teste (ou validação cruzada).
 - Métricas: Acurácia, Precisão, Recall, F1-score, AUC-ROC.
- Interpretação de resultados para validar a utilidade prática.

Coleta de dados

- Tipos
 - Logs
 - Tráfego de rede
 - Arquivos executáveis (binários)
 - Eventos de execução
- Bases públicas de malwares (amostras brutas)
- Bases públicas com características extraídas (datasets prontos para ML)

Coleta de dados

- Logs

- **Arquivos de** registros textuais de eventos em sistemas, aplicações e dispositivos de rede.
- Exemplos: tentativas de login, acessos a arquivos, falhas de autenticação.
- Útil para análise de padrões suspeitos
- Desafios: volume massivo, ruído, necessidade de padronização (ex.: formatos distintos em servidores, firewalls, sistemas operacionais).

- Tráfego de rede

- São pacotes transmitidos entre dispositivos em redes locais ou na internet.
- Coleta com ferramentas como Wireshark, tcpdump ou sensores IDS.
- Útil em detecção de botnets, C&C (comando & controle), e outros.
- Desafios: criptografia (TLS/HTTPS), alta taxa de falsos positivos.

Coleta de dados

- Arquivos executáveis (binários)

- São os programas compilados (ex.: .exe, .apk, .elf).
- Técnicas de análise:
 - Estática: inspeção sem execução (cabeçalho, strings, entropia, permissões, etc).
 - Dinâmica: execução em sandbox para observar comportamento (chamadas de API, criação de processos, etc).
- Útil em classificação de malwares; análise de variantes polimórficas.
- Desafios: obfuscação de código, packers, evasão de sandbox.

- Eventos de Execução

- São chamadas que aplicativos fazem ao sistema operacional para acessar recursos.
- Exemplos: criação de arquivos, abertura de sockets, alocação de memória.
- Útil na detecção de **comportamentos** maliciosos detectados em tempo de execução.
- Desafios: alto volume e necessidade de filtragem eficiente; distinção entre uso legítimo e malicioso.

Coleta de dados

- Bases públicas de malwares (amostras brutas)
 - VirusShare: coleção extensa de amostras de malware em binário.
 - <https://virusshare.com>
 - VirusTotal: serviço colaborativo com análise automatizada
 - Limitação: não sempre permite baixar amostras
 - <https://virustotal.com>
 - MalwareBazaar: foco em amostras recentes, disponível com hash e tags.
 - <https://abuse.ch>
 - Hybrid-Analysis: análise dinâmica em sandbox com relatórios detalhados.
 - <https://hybrid-analysis.com>
 - ANY.RUN: sandbox interativa em nuvem
 - Excelente para observação manual de malwares
 - <https://any.run>
- Desafios: necessidade de ambiente seguro (sandbox) para manuseio, confirmação que são amostras malignas e funcionais.

Coleta de dados

- Bases Públicas com Características Extraídas (datasets prontos para ML)
 - Sgandurra et al. (2016): dataset de ransomware com features extraídas (strings, entropia, APIs).
 - <https://github.com/rissgrouphub/ransomwaredataset2016>
 - CIC MalDroid 2020: características de aplicativos Android (permissões, chamadas API).
 - <https://www.unb.ca/cic/datasets/maldroid-2020.html>
 - CIC MalMem 2022: características de malware em memória.
 - <https://www.unb.ca/cic/datasets/malmem-2022.html>
 - Open Repository for the Evaluation of Ransomware Detection Tools: dataset aberto para benchmarking de ferramentas.
 - <https://ieee-dataport.org/open-access/open-repository-evaluation-ransomware-detection-tools>
 - TON_IoT Datasets: focado em IoT e sistemas ciberfísicos.
 - <https://research.unsw.edu.au/projects/toniot-datasets>
 - Coletânea de diversos datasets: agregador de datasets de segurança
 - <https://github.com/gfek/Real-CyberSecurity-Datasets>
 - Vantagens:
 - Já vêm **pré-processados (?)**; são seguros (não contêm código malicioso); normalmente são oriundos de artigos científicos
 - Desvantagens
 - Dificilmente você consegue inserir novas amostras; os datasets normalmente não são atualizados e o tempo os tornam menos relevantes

Atividade 02

1. Escreva um dos componentes do artigo final, a seção de Materiais e Métodos (parte inicial: Coleta de Dados).
 - a. Escolha um tipo (logs, tráfego de rede, arquivos executáveis, eventos de execução) e uma fonte de dados (amostras brutas ou dataset público com características extraídas) que será a base para seu artigo final (TF).
 - b. Descreva o tipo e a fonte escolhida:
 - Tipo de dado
 - Variáveis
 - Volume (por ex: quantidade a amostras)
 - Quantos malwares e quantos goodwares
 - Tipo de malwares
 - Se há subdivisão em famílias
 - Se já possui rótulos
 - Tudo o que for possível
 - c. Justifique a escolha
 - d. Caso escolha coletar amostras brutas, faça um código de coleta automatizada. Além disso, apresente onde foram/serão coletados os goodwares.
 - e. Caso escolha uma base pronta, faça um código de carregamento do dataset e que mostre as estatísticas da base.